

Presentación:

Nombre:

Algelis Severino

Tema:

Introducción y Fundamentos de Redes.

Tecnico:

Ciberseguridad Semipresencial

Facilitador:

Kevin Feliz Henriquez

Centro:

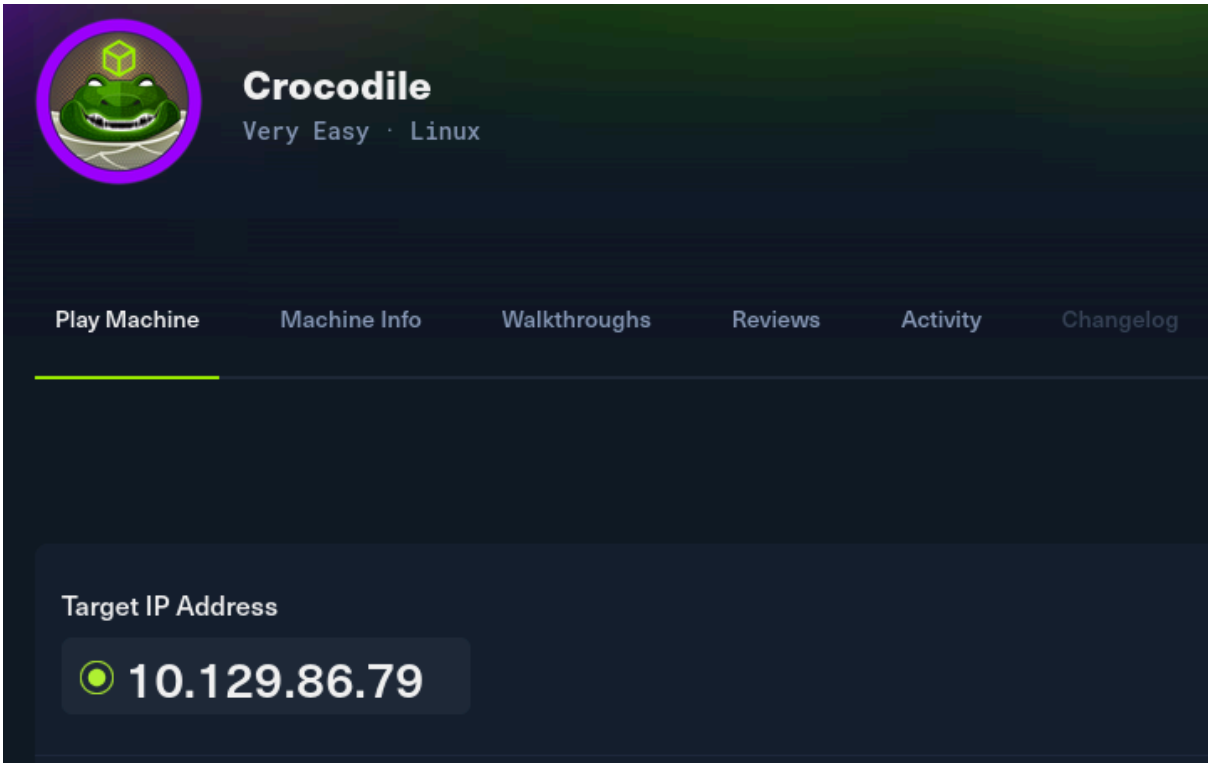
Diapiato Pro salud

Descripción:

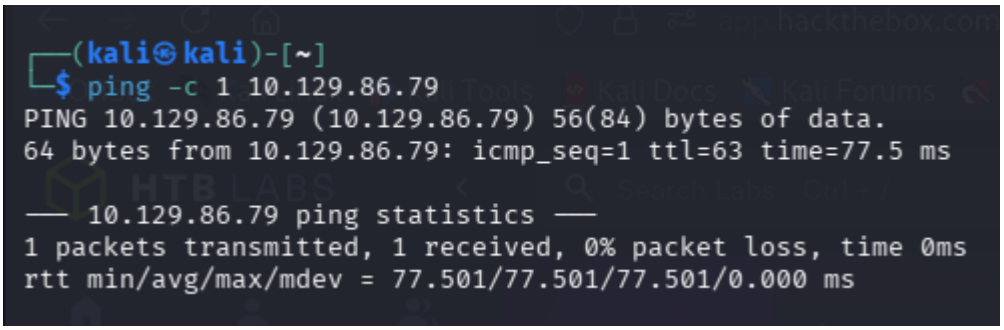
En este documento .pdf esta el paso a paso que seguí para resolver la máquina Crocodile según los hallazgos que me dio el escaneo. "Crocodile" es una máquina Linux muy fácil que muestra los peligros de una autenticación mal configurada y la exposición de datos confidenciales. Una instancia de servidor FTP vulnerable está mal configurada para permitir la autenticación anónima y, al enumerar el servidor, se pueden encontrar archivos confidenciales que contienen credenciales en texto plano. La enumeración y el *fuzzing* del sitio web revelarán un punto de acceso de inicio de

sesión oculto donde las credenciales adquiridas anteriormente se pueden utilizar para obtener acceso al panel de administración.

Dirección ip maquina victima:



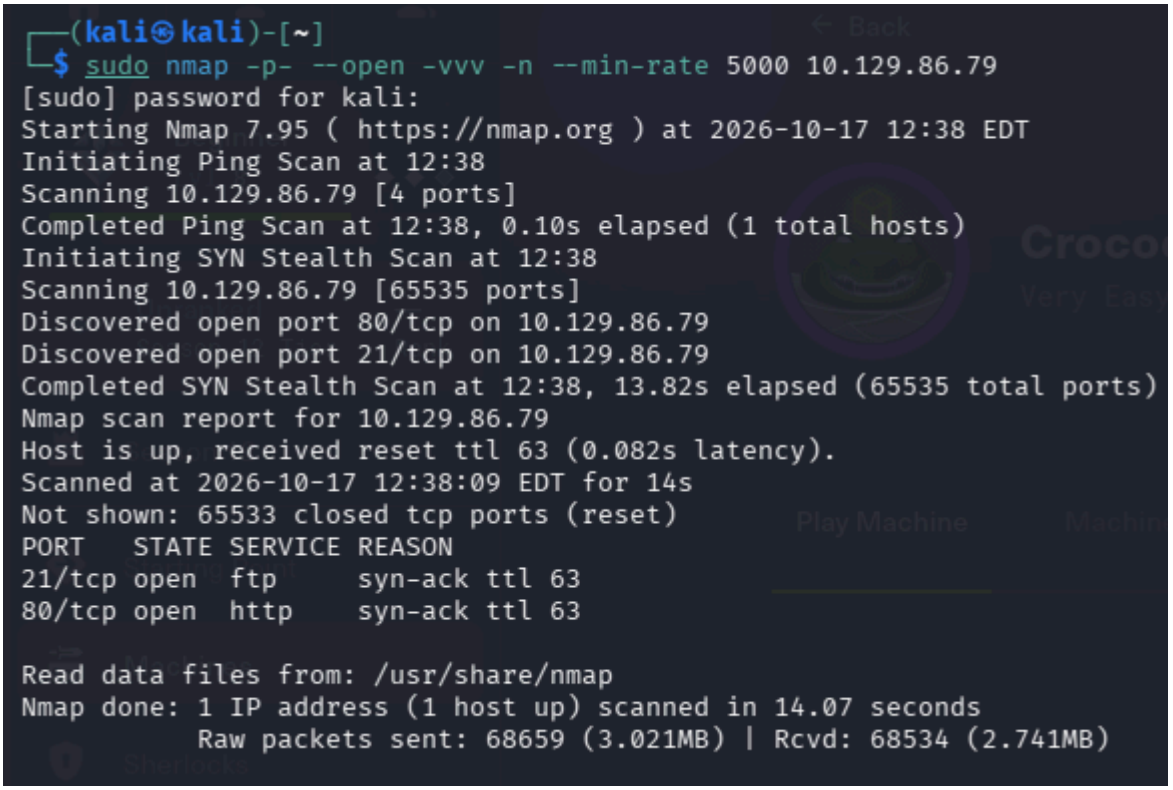
ping -c 1 10.129.86.79:
para enviar un paquete y confirmar que la máquina me responde.



Escaneo:

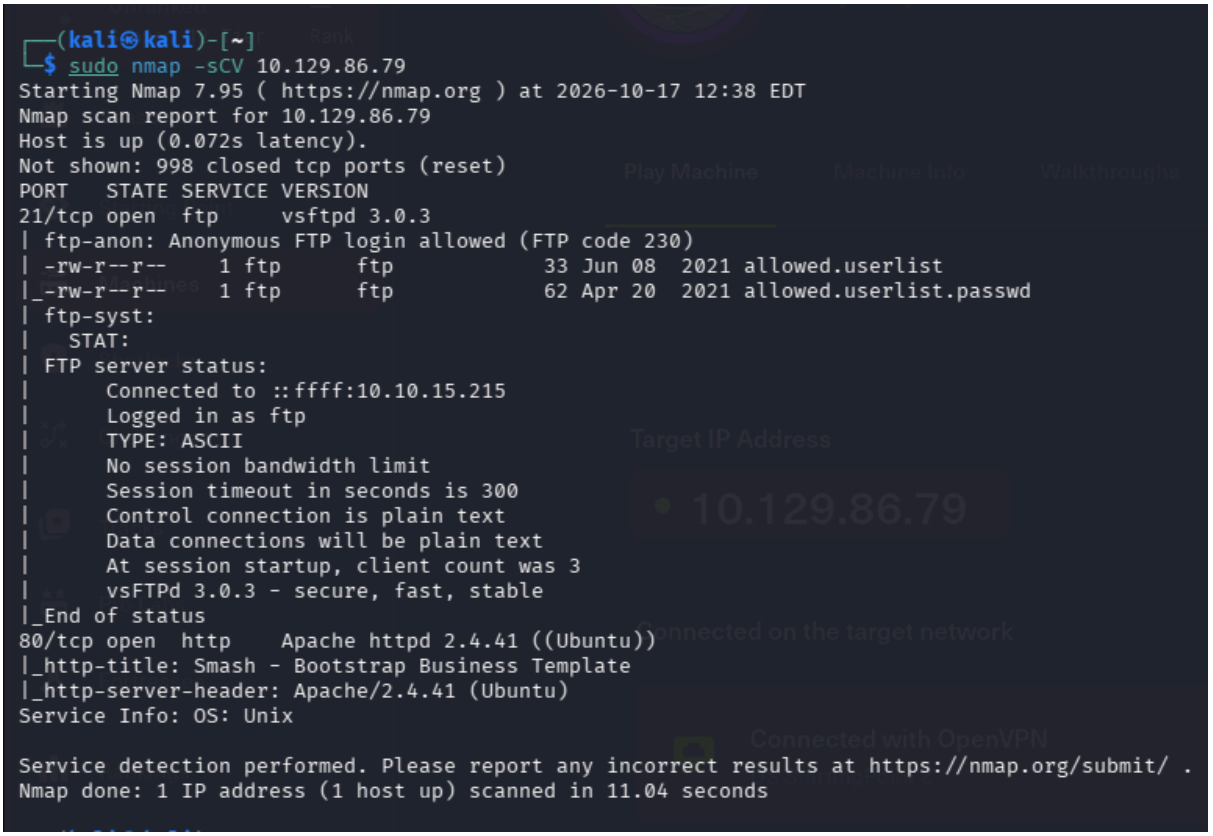
sudo nmap -p- –open -vvv -n -T5 10.129.86.79:

sudo nmap: para ejecutar nmap con privilegios elevados.
-p- –open: para indicarle a nmap que escanee todo los puertos y me muestre solo los que están abiertos.
-vvv: para que según vaya encontrando puertos me los vayas mostrando en la pantalla.
-n: para que no me aplique resolución dns.
-T5: para que el escaneo sea rápido..



sudo nmap -sCV 10.129.86.79:

para indicarle a nmap que ejecute una serie de script básicos que ya el tiene y me muestre los servicios y las versiones que estan corriendo en la maquina victima.



```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sCV 10.129.86.79
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-17 12:38 EDT
Nmap scan report for 10.129.86.79
Host is up (0.072s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--    1 ftp      ftp            33 Jun 08  2021 allowed.userlist
|_-rw-r--r--    1 ftp      ftp            62 Apr 20  2021 allowed.userlist.passwd
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:10.10.15.215
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Smash - Bootstrap Business Template
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.04 seconds
```

ftp que permite login sin contraseña y con un usuario expuesto llamada anonymous.
web corriendo en el puerto 80.

Primero voy a obtener esos archivos que veo en ftp.

```
ftp> ls -;a
229 Entering Extended Passive Mode (|||46245|)
150 Here comes the directory listing.
drwxr-xr-x    2 ftp      ftp          4096 Jun 08  2021 .
drwxr-xr-x    2 ftp      ftp          4096 Jun 08  2021 ..
-rw-r--r--    1 ftp      ftp            33 Jun 08  2021 allowed.userlist
-rw-r--r--    1 ftp      ftp            62 Apr 20  2021 allowed.userlist.passwd
226 Directory send OK.
ftp> get allowed.userlist
local: allowed.userlist remote: allowed.userlist
229 Entering Extended Passive Mode (|||41623|)
150 Opening BINARY mode data connection for allowed.userlist (33 bytes).
100% |*****************************************************************************
226 Transfer complete.
33 bytes received in 00:00 (0.42 KiB/s)
ftp> get allowed.userlist.passwd
local: allowed.userlist.passwd remote: allowed.userlist.passwd
229 Entering Extended Passive Mode (|||46290|)
150 Opening BINARY mode data connection for allowed.userlist.passwd (62 bytes).
100% |*****************************************************************************
226 Transfer complete.
62 bytes received in 00:00 (0.81 KiB/s)
ftp>
```

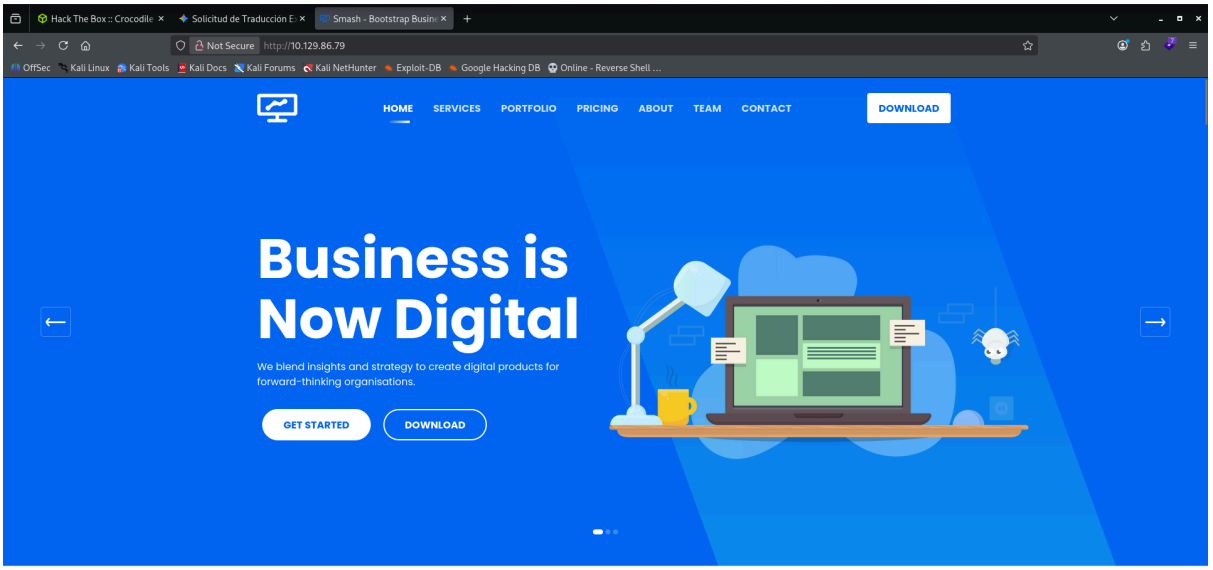
cat a los dos archivos para ver su contenido:

```
┌──(kali㉿kali)-[~]
└─$ cat allowed.userlist
aron
pwnmeow
egotisticalsw
admin

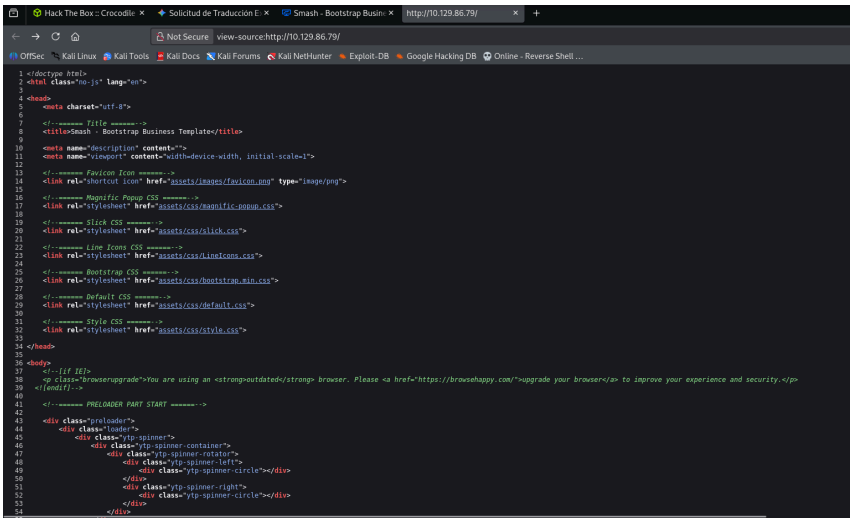
┌──(kali㉿kali)-[~]
└─$ cat allowed.userlist.passwd
root
Supersecretpassword1
@BaASD&9032123sADS
rKXM59ESxesUFHAd
```

al parecer son usuarios y contraseñas de la maquina o de la web, ahora a hechar un ojo a la web.

asi se ve la web.

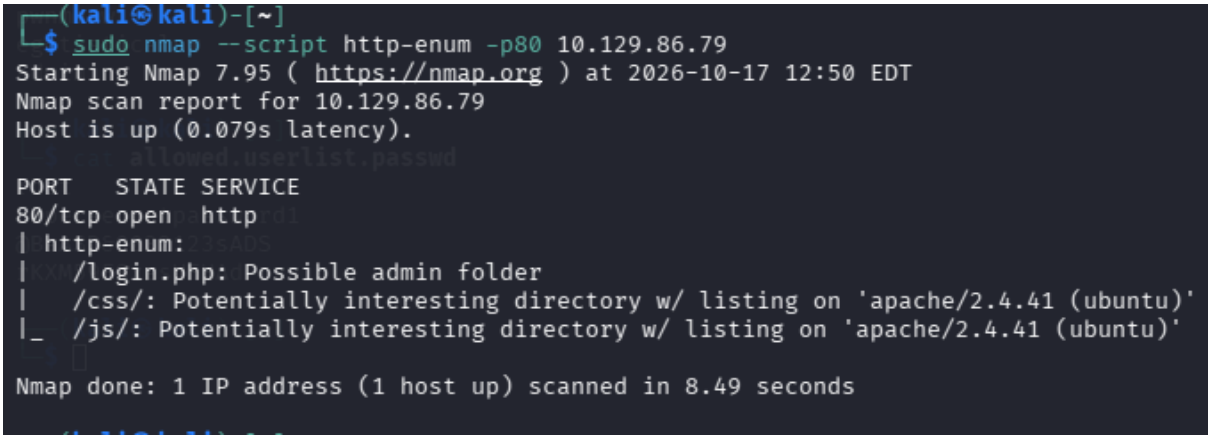


Ctrl + u: para inspeccionar el codigo fuente a ver que se encuentra.

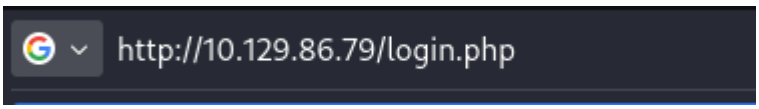


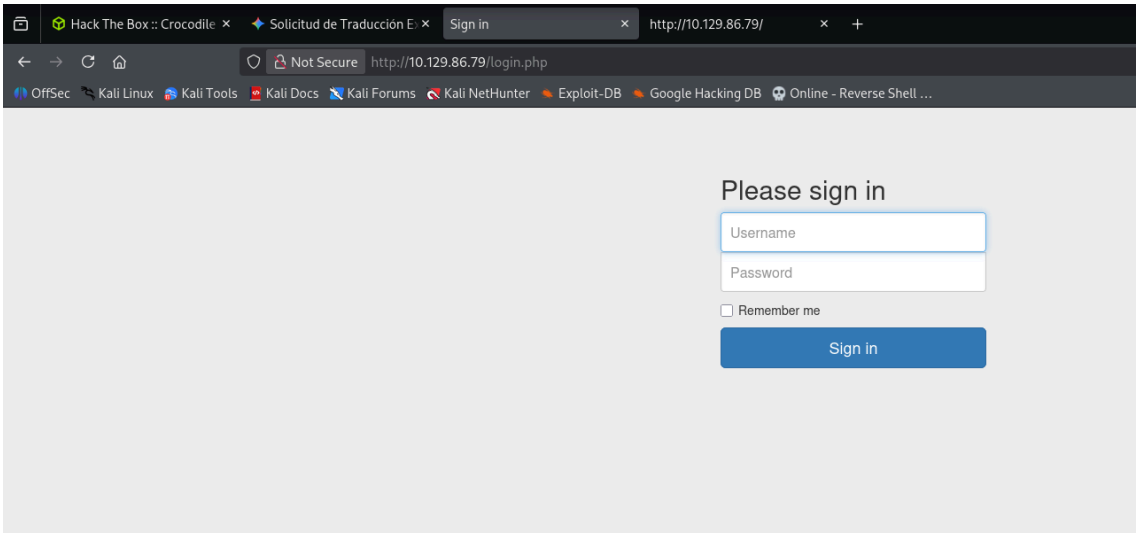
La mayoria de rutas que pude ver son de imagenes puedo usar gobuster o wfuzz para hacer fuzzing a la web y encontrar mas rutas pero prefiero usar un script de enumeracion de nmap simple:

sudo nmap –script http-enum -p80 10.129.86.79:

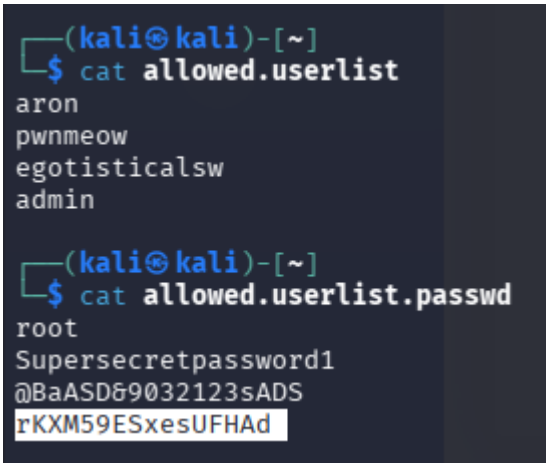


veo un login.php que podria ser otra pagina con un login y ahi puedo probar las credenciales que obtuve.

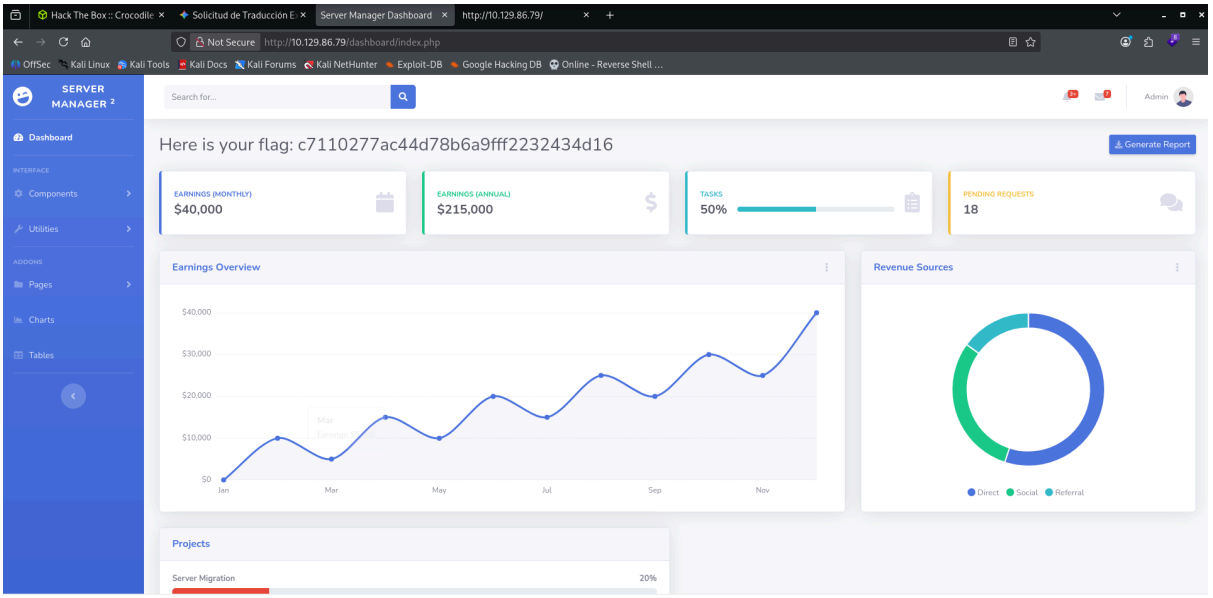




efectivamente tengo un login, ahora a probar mis credenciales.



admin y esa password que sombree me dieron el acceso a la pagina.



y ahi esta la flag.

Maquina resuelta!

